



Hardening y Firewalls

Iván Martín Carretero



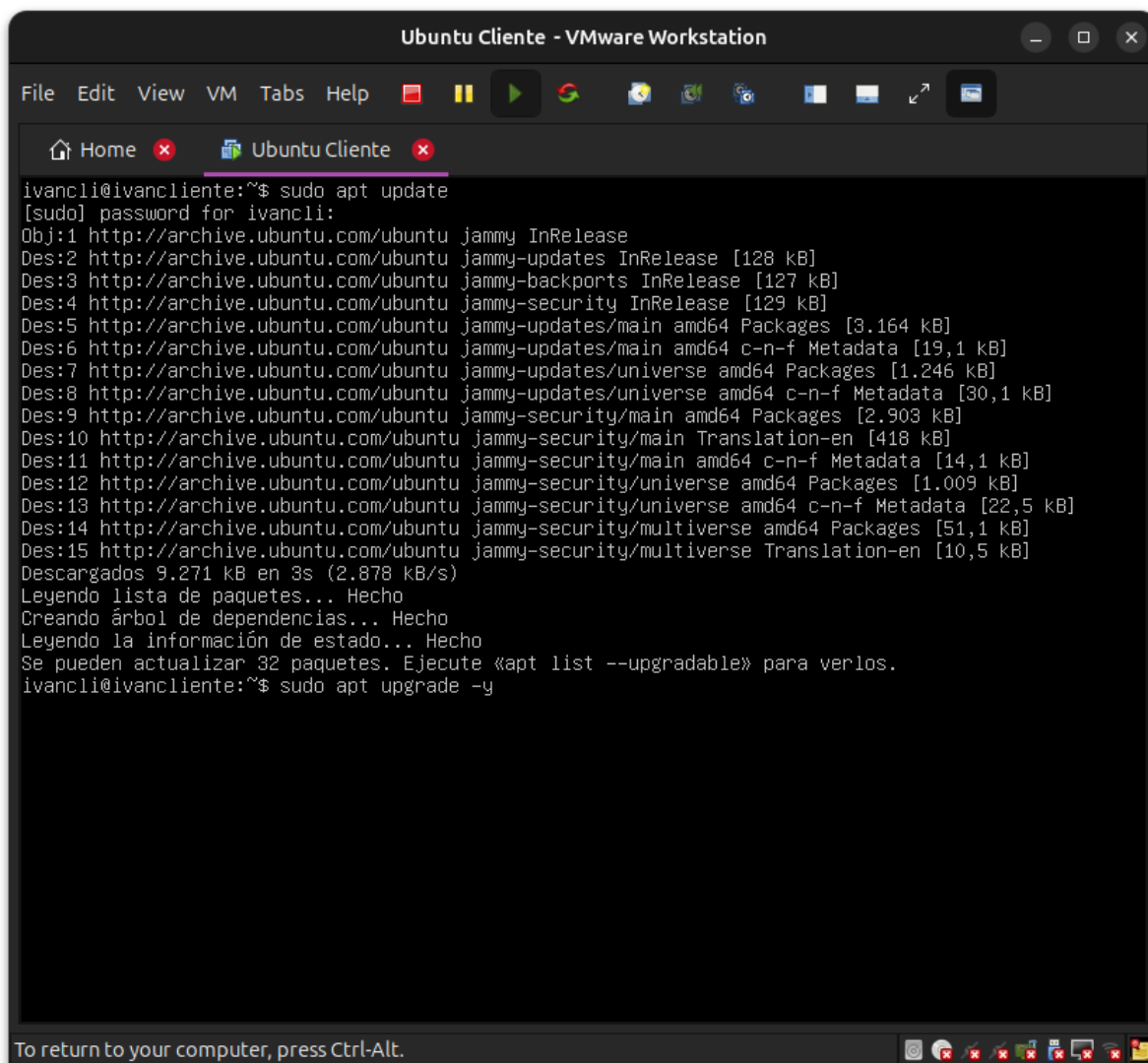
Índice

Hardening y Firewalls	1
1. Actualización del sistema	3
2. Auditoria básica del sistema con Lynis	5
3. Configuración del firewall con UFW	24
4. Protección ataques fuerza bruta con Fail2Ban	28
5. Seguridad en Capas	33
6. Conclusión final	33



Hardening y Firewalls

1. Actualización del sistema



```
ivanccli@ivanccliente:~$ sudo apt update
[sudo] password for ivanccli:
Obj:1 http://archive.ubuntu.com/ubuntu jammy InRelease
Des:2 http://archive.ubuntu.com/ubuntu jammy-updates InRelease [128 kB]
Des:3 http://archive.ubuntu.com/ubuntu jammy-backports InRelease [127 kB]
Des:4 http://archive.ubuntu.com/ubuntu jammy-security InRelease [129 kB]
Des:5 http://archive.ubuntu.com/ubuntu jammy-updates/main amd64 Packages [3.164 kB]
Des:6 http://archive.ubuntu.com/ubuntu jammy-updates/main amd64 c-n-f Metadata [19,1 kB]
Des:7 http://archive.ubuntu.com/ubuntu jammy-updates/universe amd64 Packages [1.246 kB]
Des:8 http://archive.ubuntu.com/ubuntu jammy-updates/universe amd64 c-n-f Metadata [30,1 kB]
Des:9 http://archive.ubuntu.com/ubuntu jammy-security/main amd64 Packages [2.903 kB]
Des:10 http://archive.ubuntu.com/ubuntu jammy-security/main Translation-en [418 kB]
Des:11 http://archive.ubuntu.com/ubuntu jammy-security/main amd64 c-n-f Metadata [14,1 kB]
Des:12 http://archive.ubuntu.com/ubuntu jammy-security/universe amd64 Packages [1.009 kB]
Des:13 http://archive.ubuntu.com/ubuntu jammy-security/universe amd64 c-n-f Metadata [22,5 kB]
Des:14 http://archive.ubuntu.com/ubuntu jammy-security/multiverse amd64 Packages [51,1 kB]
Des:15 http://archive.ubuntu.com/ubuntu jammy-security/multiverse Translation-en [10,5 kB]
Descargados 9.271 kB en 3s (2.878 kB/s)
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se pueden actualizar 32 paquetes. Ejecute «apt list --upgradable» para verlos.
ivanccli@ivanccliente:~$ sudo apt upgrade -y
```

Para actualizar el sistema tendremos que ir a la terminal y escribir el **comando sudo apt update** para poder actualizar los paquetes

Cuando tengamos los paquetes actualizados ejecutaremos el **comando sudo apt upgrade -y** para ya instalar las actualizaciones en el sistema



```
[*] multipathd.service
[*] networkd-dispatcher.service
[*] open-vm-tools.service
[*] packagekit.service
[*] polkit.service
[*] rsyslog.service
[*] ssh.service
[*] systemd-journald.service
[*] systemd-logind.service
[*] systemd-networkd.service
[*] systemd-resolved.service
[*] systemd-timesyncd.service
[*] systemd-udev.service
[*] udisks2.service
[*] unattended-upgrades.service
[*] user@1000.service
[*] vgauth.service

<Ok> <Cancel>

/etc/needrestart/restart.d/dbus.service
systemctl restart cron.service irqbalance.service ModemManager.service multipathd.service networkd-
dispatcher.service open-vm-tools.service packagekit.service polkit.service rsyslog.service ssh.servi
ce systemd-journald.service systemd-logind.service systemd-networkd.service systemd-resolved.service
systemd-timesyncd.service systemd-udev.service udisks2.service unattended-upgrades.service user@10
00.service vgauth.service

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
ivanc11@ivanc1iente:~$ sudo reboot _

To return to your computer, press Ctrl-Alt.
```

Ahora reiniciaremos el sistema para que las actualizaciones se instalen correctamente en el sistema. Para eso ejecutaremos el **comando sudo reboot**

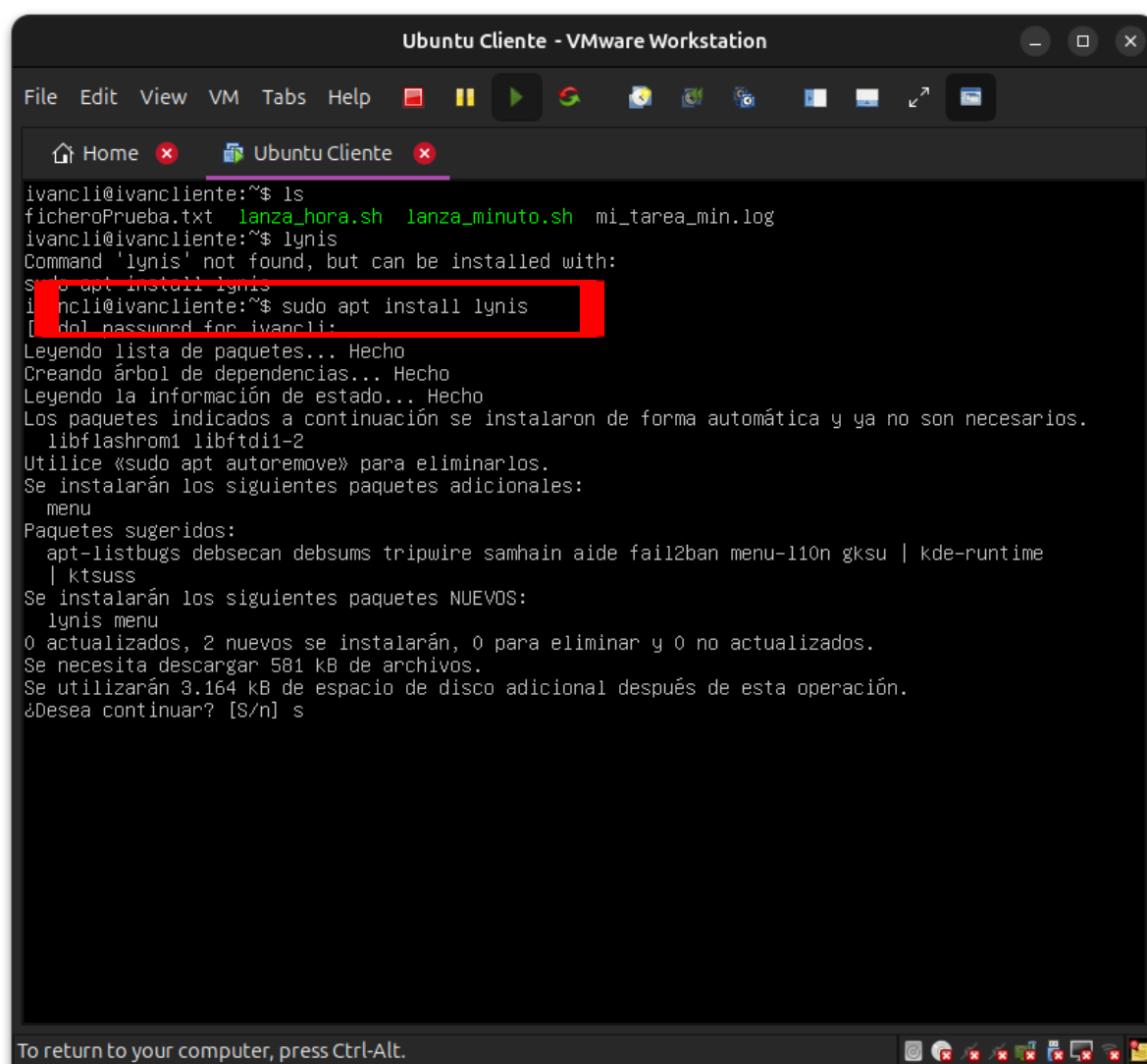
¿Por qué es importante mantener el sistema actualizado desde el punto de vista de la seguridad?

Es importante mantener el sistema actualizado para corregir las vulnerabilidades, para que no se puedan usar los exploits mediante



malware y al final un sistema con un software, dependencias y configuraciones desactualizadas es más fácil de atacar

2. Auditoria básica del sistema con Lynis



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
ivanccli@ivanccliente:~$ ls
ficheroPrueba.txt lanza_hora.sh lanza_minuto.sh mi_tarea_min.log
ivanccli@ivanccliente:~$ lynis
Command 'lynis' not found, but can be installed with:
sudo apt install lynis
ivanccli@ivanccliente:~$ sudo apt install lynis
[Enter password for ivanccli]
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesarios.
  libflashrom1 libftdi1-2
Utilice «sudo apt autoremove» para eliminarlos.
Se instalarán los siguientes paquetes adicionales:
  menu
Paquetes sugeridos:
  apt-listbugs debsecan debsums tripwire samhain aide fail2ban menu-l10n gksu | kde-runtime
  | ktsuss
Se instalarán los siguientes paquetes NUEVOS:
  lynis menu
0 actualizados, 2 nuevos se instalarán, 0 para eliminar y 0 no actualizados.
Se necesita descargar 581 kB de archivos.
Se utilizarán 3.164 kB de espacio de disco adicional después de esta operación.
¿Desea continuar? [S/n] s
```



Para instalar el servicio de Lynis tendremos que ejecutar el **comando**
sudo apt install lynis

Ahora ejecutaremos la auditoría del sistema y la enviaremos a un archivo que se creará llamado auditoria.log para así poder analizarlo de manera más cómoda

Ejecutaremos el **comando sudo lynis audit system > auditoria.log** y mediante un cat al archivo auditoria.log lo veremos



```
Hardening index : 60 [##### ]
Tests performed : 255
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====

Lynis 3.0.7

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/d
efault.prfl for all settings)

ivancali@ivancali:~$ _
```

Una vez que revisamos el archivo abajo del todo encontraremos la puntuación que lynis nos da sobre nuestro sistema, en mi caso me ha dado un 60 sobre 100



```
-----
- Checking default run level [ RUNLEVEL 5 ]
- Checking CPU support (NX/PAE) [ ENCONTRADO ]
  CPU support: PAE and/or NoeXecute supported [ HECHO ]
- Checking kernel version and release [ HECHO ]
- Checking kernel type [ HECHO ]
- Checking loaded kernel modules [ HECHO ]
  Found 84 active modules
- Checking Linux kernel configuration file [ ENCONTRADO ]
- Checking default I/O kernel scheduler [ NO ENCONTRADO ]
- Checking for available kernel update [ OK ]
- Checking core dumps configuration
  - configuration in systemd conf files [ POR DEFECTO ]
  - configuration in etc/profile [ POR DEFECTO ]
  - 'hard' configuration in security/limits.conf [ POR DEFECTO ]
  - 'soft' configuration in security/limits.conf [ POR DEFECTO ]
  - Checking setuid core dumps configuration [ PROTEGIDO ]
- Check if reboot is needed [ NO ]

[+] Memoria y procesos
-----
- Checking /proc/meminfo [ ENCONTRADO ]
- Searching for dead/zombie processes [ NO ENCONTRADO ]
- Searching for IO waiting processes [ NO ENCONTRADO ]
- Search prelink tooling [ NO ENCONTRADO ]

[+] Usuarios, grupos y autenticación
-----
- Administrator accounts [ OK ]
- Unique UIDs [ OK ]
- Consistency of group files (grpck) [ OK ]
- Unique group IDs [ OK ]
- Unique group names [ OK ]
- Password file consistency [ OK ]
- Password hashing methods [ SUGERENCIA ]
- Checking password hashing rounds [ DESHABILITADO ]

--More--
```

To return to your computer, press Ctrl-Alt.



```
Ubuntu Cliente - VMware Workstation

File Edit View VM Tabs Help

Home x Ubuntu Cliente x

- Query system users (non daemons) [ HECHO ]
- NIS+ authentication support [ NO HABILITADO ]
- NIS authentication support [ NO HABILITADO ]
- Sudoers file(s) [ ENCONTRADO ]
  - Permissions for directory: /etc/sudoers.d [ PELIGRO ]
  - Permissions for: /etc/sudoers [ OK ]
  - Permissions for: /etc/sudoers.d/README [ OK ]
- PAM password strength tools [ SUGERENCIA ]
- PAM configuration files (pam.conf) [ ENCONTRADO ]
- PAM configuration files (pam.d) [ ENCONTRADO ]
- PAM modules [ ENCONTRADO ]
- LDAP module in PAM [ NO ENCONTRADO ]
- Accounts without expire date [ SUGERENCIA ]
- Accounts without password [ OK ]
- Locked accounts [ ENCONTRADO ]
- Checking user password aging (minimum) [ DESHABILITADO ]
- User password aging (maximum) [ DESHABILITADO ]
- Checking expired passwords [ OK ]
- Checking Linux single user mode authentication [ OK ]
- Determining default umask
  - umask (/etc/profile) [ NO ENCONTRADO ]
  - umask (/etc/login.defs) [ SUGERENCIA ]
- LDAP authentication support [ NO HABILITADO ]
- Logging failed login attempts [ HABILITADO ]

[+] Shells
-----
- Checking shells from /etc/shells
  Result: found 10 shells (valid shells: 10).
  - Session timeout settings/tools [ NINGUNO ]
- Checking default umask values
  - Checking default umask in /etc/bash.bashrc [ NINGUNO ]
  - Checking default umask in /etc/profile [ NINGUNO ]

[+] Sistemas de ficheros
-----
--More--

To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
- Checking mount points
  - Checking /home mount point [ SUGERENCIA ]
  - Checking /tmp mount point [ SUGERENCIA ]
  - Checking /var mount point [ SUGERENCIA ]
  - Checking LVM volume groups [ ENCONTRADO ]
  - Checking LVM volumes [ ENCONTRADO ]
  - Query swap partitions (fstab) [ NINGUNO ]
  - Testing swap partitions [ OK ]
  - Testing /proc mount (hidepid) [ SUGERENCIA ]
  - Checking for old files in /tmp [ OK ]
  - Checking /tmp sticky bit [ OK ]
  - Checking /var/tmp sticky bit [ OK ]
  - ACL support root file system [ HABILITADO ]
  - Mount options of / [ OK ]
  - Mount options of /boot [ POR DEFECTO ]
  - Mount options of /dev [ PARCIALMENTE BASTIONADO ]
  - Mount options of /dev/shm [ PARCIALMENTE BASTIONADO ]
  - Mount options of /run [ BASTIONADO ]
  - Total without nodev:7 noexec:14 nosuid:11 ro or noexec (W^X): 8 of total 31
  - Disable kernel support of some filesystems

[+] Dispositivos USB
-----
  - Checking usb-storage driver (modprobe config) [ NO DESHABILITADO ]
  - Checking USB devices authorization [ HABILITADO ]
  - Checking USBGuard [ NO ENCONTRADO ]

[+] Almacenamiento
-----
  - Checking firewire ohci driver (modprobe config) [ DESHABILITADO ]

[+] NFS
-----
  - Check running NFS daemon [ NO ENCONTRADO ]

[+] Servicios de nombres
--More--
To return to your computer, press Ctrl-Alt.
```



```
-----
- Checking search domains [ ENCONTRADO ]
- Checking /etc/resolv.conf options [ ENCONTRADO ]
- Searching DNS domain name [ DESCONOCIDO ]
- Checking /etc/hosts
  - Duplicate entries in hosts file [ NINGUNO ]
  - Presence of configured hostname in /etc/hosts [ ENCONTRADO ]
  - Hostname mapped to localhost [ NO ENCONTRADO ]
  - Localhost mapping to IP address [ OK ]

[+] Puertos y paquetes
-----
- Searching package managers
  - Searching dpkg package manager [ ENCONTRADO ]
  - Querying package manager [ ENCONTRADO ]
  - Query unpurged packages [ OK ]
- Checking security repository in sources.list file [ OK ]
- Checking APT package database [ OK ]
- Checking vulnerable packages [ OK ]
- Checking upgradeable packages [ OMITIDO ]
- Checking package audit tool [ INSTALADO ]
Found: apt-check
- Toolkit for automatic upgrades (unattended-upgrade) [ ENCONTRADO ]

[+] Conectividad
-----
- Checking IPv6 configuration [ HABILITADO ]
  Configuration method [ AUTO ]
  IPv6 only [ NO ]
- Checking configured nameservers
  - Testing nameservers
    Nameserver: 127.0.0.53 [ OK ]
  - DNSSEC supported (systemd-resolved) [ NO ]
- Getting listening ports (TCP/UDP) [ HECHO ]
- Checking promiscuous interfaces [ OK ]
- Checking status DHCP client

--More--

To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
- Checking for ARP monitoring software [ NO ENCONTRADO ]
- Uncommon network protocols [ 0 ]

[+] Impresoras y spools
-----
- Checking cups daemon [ NO ENCONTRADO ]
- Checking lp daemon [ NO ESTÁ CORRIENDO ]

[+] Software: correo electrónico y mensajería
-----

[+] Software: firewalls
-----
- Checking iptables kernel module [ ENCONTRADO ]
- Checking iptables policies of chains [ ENCONTRADO ]
- Checking for empty ruleset [ PELIGRO ]
- Checking for unused rules [ OK ]
- Checking host based firewall [ ACTIVO ]

[+] Software: servidor web
-----
- Checking Apache [ NO ENCONTRADO ]
- Checking nginx [ NO ENCONTRADO ]

[+] Soporte SSH
-----
- Checking running SSH daemon [ ENCONTRADO ]
- Searching SSH configuration [ ENCONTRADO ]
- OpenSSH option: AllowTcpForwarding [ SUGERENCIA ]
- OpenSSH option: ClientAliveCountMax [ SUGERENCIA ]
- OpenSSH option: ClientAliveInterval [ OK ]
- OpenSSH option: Compression [ SUGERENCIA ]
- OpenSSH option: FingerprintHash [ OK ]
- OpenSSH option: GatewayPorts [ OK ]
- OpenSSH option: IgnoreRhosts [ OK ]
- OpenSSH option: LoginGraceTime [ OK ]
--More--

To return to your computer, press Ctrl-Alt.
```



```
--More-- OpenSSH option: LogLevel [ SUGERENCIA ]
- OpenSSH option: MaxAuthTries [ SUGERENCIA ]
- OpenSSH option: MaxSessions [ SUGERENCIA ]
- OpenSSH option: PermitRootLogin [ OK ]
- OpenSSH option: PermitUserEnvironment [ OK ]
- OpenSSH option: PermitTunnel [ OK ]
- OpenSSH option: Port [ SUGERENCIA ]
- OpenSSH option: PrintLastLog [ OK ]
- OpenSSH option: StrictModes [ OK ]
- OpenSSH option: TCPKeepAlive [ SUGERENCIA ]
- OpenSSH option: UsedDNS [ OK ]
- OpenSSH option: X11Forwarding [ SUGERENCIA ]
- OpenSSH option: AllowAgentForwarding [ SUGERENCIA ]
- OpenSSH option: AllowUsers [ NO ENCONTRADO ]
- OpenSSH option: AllowGroups [ NO ENCONTRADO ]

[+] SopORTE SNMP
-----
- Checking running SNMP daemon [ NO ENCONTRADO ]

[+] Bases de datos
-----
No database engines found

[+] Servicios LDAP
-----
- Checking OpenLDAP instance [ NO ENCONTRADO ]

[+] PHP
-----
- Checking PHP [ NO ENCONTRADO ]

[+] SopORTE Squid
-----
- Checking running Squid daemon [ NO ENCONTRADO ]

--More--
```

To return to your computer, press Ctrl-Alt.



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
[+] Logging y ficheros
-----
- Checking for a running log daemon [ OK ]
- Checking Syslog-NG status [ NO ENCONTRADO ]
- Checking systemd journal status [ ENCONTRADO ]
- Checking Metalog status [ NO ENCONTRADO ]
- Checking RSyslog status [ ENCONTRADO ]
- Checking RFC 3195 daemon status [ NO ENCONTRADO ]
- Checking minilogd instances [ NO ENCONTRADO ]
- Checking logrotate presence [ OK ]
- Checking remote logging [ NO HABILITADO ]
- Checking log directories (static list) [ HECHO ]
- Checking open log files [ HECHO ]
- Checking deleted files in use [ HECHO ]

[+] Servicios inseguros
-----
- Installed inetd package [ NO ENCONTRADO ]
- Installed xinetd package [ OK ]
- xinetd status
- Installed rsh client package [ OK ]
- Installed rsh server package [ OK ]
- Installed telnet client package [ OK ]
- Installed telnet server package [ NO ENCONTRADO ]
- Checking NIS client installation [ OK ]
- Checking NIS server installation [ OK ]
- Checking TFTP client installation [ OK ]
- Checking TFTP server installation [ OK ]

[+] Banners e identificación
-----
- /etc/issue [ ENCONTRADO ]
- /etc/issue contents [ DÉBIL ]
- /etc/issue.net [ ENCONTRADO ]
- /etc/issue.net contents [ DÉBIL ]

--More--
To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
[+] Tareas programadas
-----
- Checking crontab and cronjob files [ HECHO ]
[+] Contabilidad
-----
- Checking accounting information [ NO ENCONTRADO ]
- Checking sysstat accounting data [ NO ENCONTRADO ]
- Checking auditd [ NO ENCONTRADO ]
[+] Tiempo y sincronización
-----
- NTP daemon found: systemd (timesyncd) [ ENCONTRADO ]
- Checking for a running NTP daemon or client [ OK ]
- Last time synchronization [ 311s ]
[+] Criptografía
-----
- Checking for expired SSL certificates [0/150] [ NINGUNO ]
[WARNING]: Test CRYPT-7902 had a long execution: 13.002836 seconds
- Found 0 encrypted and 0 unencrypted swap devices in use. [ OK ]
- Kernel entropy is sufficient [ SÍ ]
- HW RNG & rngd [ NO ]
- SW prng [ NO ]
- MDR variable not found [ DÉBIL ]
[+] Virtualización
-----
[+] Contenedores
-----
[+] Frameworks de seguridad
-----
--More--
To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation

File Edit View VM Tabs Help

Home x Ubuntu Cliente x

- Checking presence AppArmor [ ENCONTRADO ]
  - Checking AppArmor status [ HABILITADO ]
    Found 34 unconfined processes
  - Checking presence SELinux [ NO ENCONTRADO ]
  - Checking presence TOMOYO Linux [ NO ENCONTRADO ]
  - Checking presence grsecurity [ NO ENCONTRADO ]
  - Checking for implemented MAC framework [ OK ]

[+] Software: integridad de ficheros
-----
- Checking file integrity tools
- dm-integrity (status) [ DESHABILITADO ]
- dm-verity (status) [ DESHABILITADO ]
- Checking presence integrity tool [ NO ENCONTRADO ]

[+] Software: Herramientas del sistema
-----
- Checking automation tooling
- Automation tooling [ NO ENCONTRADO ]
- Checking for IDS/IPS tooling [ NINGUNO ]

[+] Software: Malware
-----
- Malware software components [ NO ENCONTRADO ]

[+] Permisos de ficheros
-----
- Starting file permissions check
  File: /boot/grub/grub.cfg [ SUGERENCIA ]
  File: /etc/crontab [ SUGERENCIA ]
  File: /etc/group [ OK ]
  File: /etc/group- [ OK ]
  File: /etc/hosts.allow [ OK ]
  File: /etc/hosts.deny [ OK ]
  File: /etc/issue [ OK ]
  File: /etc/issue.net [ OK ]
--More--

To return to your computer, press Ctrl-Alt.
```




```
--More--
File: /etc/passwd [ OK ]
File: /etc/passwd- [ OK ]
File: /etc/ssh/ssh_config [ SUGERENCIA ]
Directory: /root/.ssh [ OK ]
Directory: /etc/cron.d [ SUGERENCIA ]
Directory: /etc/cron.daily [ SUGERENCIA ]
Directory: /etc/cron.hourly [ SUGERENCIA ]
Directory: /etc/cron.weekly [ SUGERENCIA ]
Directory: /etc/cron.monthly [ SUGERENCIA ]

[+] Directorios de inicio
-----
- Permissions of home directories [ OK ]
- Ownership of home directories [ OK ]
- Checking shell history files [ OK ]

[+] Bastionado del kernel
-----
- Comparing sysctl key pairs with scan profile
  - dev.tty.ldisc_autoload (exp: 0) [ DIFERENTE ]
  - fs.protected_fifos (exp: 2) [ DIFERENTE ]
  - fs.protected_hardlinks (exp: 1) [ OK ]
  - fs.protected_regular (exp: 2) [ OK ]
  - fs.protected_symlinks (exp: 1) [ OK ]
  - fs.suid_dumpable (exp: 0) [ DIFERENTE ]
  - kernel.core_uses_pid (exp: 1) [ OK ]
  - kernel.ctrl-alt-del (exp: 0) [ OK ]
  - kernel.dmesg_restrict (exp: 1) [ OK ]
  - kernel.kptr_restrict (exp: 2) [ DIFERENTE ]
  - kernel.modules_disabled (exp: 1) [ DIFERENTE ]
  - kernel.perf_event_paranoid (exp: 3) [ DIFERENTE ]
  - kernel.randomize_va_space (exp: 2) [ OK ]
  - kernel.sysrq (exp: 0) [ DIFERENTE ]
  - kernel.unprivileged_bpf_disabled (exp: 1) [ DIFERENTE ]
  - kernel.yama.ptrace_scope (exp: 1 2 3) [ OK ]
  - net.core.bpf_jit_harden (exp: 2) [ DIFERENTE ]

--More--
```

To return to your computer, press Ctrl-Alt.

Aquí podemos encontrar las sugerencias principales indicándonos sobre que es la sugerencia en amarillo y medidas urgentes de peligro en rojo



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
-[ Lynis 3.0.7 Results ]-
Warnings (1):
-----
! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/lynis/controls/FIRE-4512/
Suggestions (50):
-----
* This release is more than 4 months old. Check the website or GitHub to see if there is
an update available. [LYNIS]
  https://cisofy.com/lynis/controls/LYNIS/
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
  https://cisofy.com/lynis/controls/DEB-0280/
* Install apt-listbugs to display a list of critical bugs prior to each APT installation.
[DEB-0810]
  https://cisofy.com/lynis/controls/DEB-0810/
* Install apt-listchanges to display any significant changes prior to any upgrade via APT
. [DEB-0811]
  https://cisofy.com/lynis/controls/DEB-0811/
* Install fail2ban to automatically ban hosts that commit multiple authentication errors.
[DEB-0880]
  https://cisofy.com/lynis/controls/DEB-0880/
* Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in
single user mode without password) [BOOT-5122]
  https://cisofy.com/lynis/controls/BOOT-5122/
* Consider hardening system services [BOOT-5264]
  - Details : Run '/usr/bin/systemd-analyze security SERVICE' for each service
  https://cisofy.com/lynis/controls/BOOT-5264/
--More--
To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
* If not required, consider explicit disabling of core dump in /etc/security/limits.conf
file [KRNL-5820]
  https://cisofy.com/lynis/controls/KRNL-5820/
* Check PAM configuration, add rounds if applicable and expire passwords to encrypt with
new values [AUTH-9229]
  https://cisofy.com/lynis/controls/AUTH-9229/
* Configure password hashing rounds in /etc/login.defs [AUTH-9230]
  https://cisofy.com/lynis/controls/AUTH-9230/
* Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc [A
UTH-9262]
  https://cisofy.com/lynis/controls/AUTH-9262/
* When possible set expire dates for all password protected accounts [AUTH-9282]
  https://cisofy.com/lynis/controls/AUTH-9282/
* Look at the locked accounts and consider removing them [AUTH-9284]
  https://cisofy.com/lynis/controls/AUTH-9284/
* Configure minimum password age in /etc/login.defs [AUTH-9286]
  https://cisofy.com/lynis/controls/AUTH-9286/
* Configure maximum password age in /etc/login.defs [AUTH-9286]
  https://cisofy.com/lynis/controls/AUTH-9286/
* Default umask in /etc/login.defs could be more strict like 027 [AUTH-9328]
  https://cisofy.com/lynis/controls/AUTH-9328/
* To decrease the impact of a full /home file system, place /home on a separate partition
[FILE-6310]
  https://cisofy.com/lynis/controls/FILE-6310/
* To decrease the impact of a full /tmp file system, place /tmp on a separate partition [
FILE-6310]
--More--
To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
https://cisofy.com/lynis/controls/FILE-6310/
* To decrease the impact of a full /var file system, place /var on a separate partition [
FILE-6310]
https://cisofy.com/lynis/controls/FILE-6310/
* Disable drivers like USB storage when not used, to prevent unauthorized storage or data
theft [USB-1000]
https://cisofy.com/lynis/controls/USB-1000/
* Check DNS configuration for the dns domain name [NAME-4028]
https://cisofy.com/lynis/controls/NAME-4028/
* Purge old/removed packages (6 found) with aptitude purge or dpkg --purge command. This
will cleanup old configuration files, cron jobs and startup scripts. [PKGS-7346]
https://cisofy.com/lynis/controls/PKGS-7346/
* Install debsums utility for the verification of packages with known good database. [PKG
S-7370]
https://cisofy.com/lynis/controls/PKGS-7370/
* Install package apt-show-versions for patch management purposes [PKGS-7394]
https://cisofy.com/lynis/controls/PKGS-7394/
* Determine if protocol 'dccp' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/
* Determine if protocol 'sctp' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/
* Determine if protocol 'rds' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/
* Determine if protocol 'tipc' is really needed on this system [NETW-3200]
https://cisofy.com/lynis/controls/NETW-3200/
--More--
To return to your computer, press Ctrl-Alt.
```



```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
* Consider hardening SSH configuration [SSH-7408]
- Details : AllowTcpForwarding (set YES to NO)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : ClientAliveCountMax (set 3 to 2)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : Compression (set YES to NO)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : LogLevel (set INFO to VERBOSE)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : MaxAuthTries (set 6 to 3)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : MaxSessions (set 10 to 2)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : Port (set 22 to )
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : TCPKeepAlive (set YES to NO)
https://cisofy.com/lynis/controls/SSH-7408/
* Consider hardening SSH configuration [SSH-7408]
- Details : X11Forwarding (set YES to NO)
https://cisofy.com/lynis/controls/SSH-7408/
--More--
To return to your computer, press Ctrl-Alt.
```



Más abajo encontramos el apartado de las recomendaciones donde te da los detalles de lo que deberías de mejorar en tu sistema. En mi caso hay 50 recomendaciones

```
root@ubuntu:/home/ubuntu# chmod 400 /etc/crontab
root@ubuntu:/home/ubuntu# ls -l /etc/crontab
-r----- 1 root root 1136 Mar 23 2022 /etc/crontab
root@ubuntu:/home/ubuntu#
```

```
root@ubuntu:/home/ubuntu# ls -l /boot/grub/grub.cfg
-r----- 1 root root 9028 Dec 11 14:38 /boot/grub/grub.cfg
root@ubuntu:/home/ubuntu#
```



Ahora voy a solucionar dos sugerencias que me dice lynis que son de permisos sobre crontab y el grub del sistema. Para eso ejecutaremos el **comando chmod 400 /etc/crontab** para que solo el usuario tenga permisos sobre dicho servicio

Con el otro servicio haremos lo mismo ejecutando el comando **chmod 400 /boot/grub/grub.cfg**

```
Hardening index : 63 [#####]
Tests performed : 270
Plugins enabled : 1
```

Y como podemos ver después de reiniciar el sistema y volver a ejecutar el servicio de lynis el porcentaje del Hardening a subido a un 63 %

¿Qué problemas de seguridad detecta Lynis?

Detecta problemas de permisos, problemas de cifrado de contraseñas y archivos, también encontramos un aviso peligroso sobre qué iptables está instalado pero no tiene ninguna regla por lo que el tráfico no se está filtrando correctamente

¿Qué tipo de mejoras propone?

Nos propone instalar fail2ban para poder bloquear las IPs que intenten hacer un ataque de fuerza bruta para acceder al usuario, nos propone instalar apt-listbugs que nos alerta sobre errores críticos de



paquetes y apt-listchanges que nos muestra los cambios importantes que tiene una actualización, entre otras mejoras

3. Configuración del firewall con UFW

```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
ivancli@ivanciente:~$ sudo sytemctl status ufw
sudo: sytemctl: command not found
ivancli@ivanciente:~$ sudo systemctl status ufw
• ufw.service - Uncomplicated firewall
  Loaded: loaded (/lib/systemd/system/ufw.service; enabled; vendor preset: enabled)
  Active: active (exited) since Fri 2026-01-23 14:35:36 UTC; 13min ago
  Docs: man:ufw(8)
  Main PID: 676 (code=exited, status=0/SUCCESS)
  CPU: 2ms

ene 23 14:35:36 ivanciente systemd[1]: Starting Uncomplicated firewall...
ene 23 14:35:36 ivanciente systemd[1]: Finished Uncomplicated firewall.
ivancli@ivanciente:~$ _
```

To return to your computer, press Ctrl-Alt.

Para comprobar el estado del firewall ejecutaremos el **comando sudo systemctl status ufw** y como en mi caso podemos ver **active (running)** en verde lo que significa que está activo



Ahora vamos a permitir solo el tráfico saliente pero vamos a denegar el tráfico entrante

Para denegar el tráfico entrante ejecutaremos el **comando sudo ufw default deny incoming** y para permitir el tráfico saliente ejecutaremos el **comando sudo ufw default allow outgoing**

```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
ivancli@ivancli:~$ sudo ufw allow https
Rules updated
Rules updated (v6)
ivancli@ivancli:~$ sudo ufw allow ssh
Skipping adding existing rule
Skipping adding existing rule (v6)
ivancli@ivancli:~$ sudo systemctl enable ufw
Synchronizing state of ufw.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable ufw
ivancli@ivancli:~$ sudo systemctl status ufw
• ufw.service - Uncomplicated Firewall
   Loaded: loaded (/lib/systemd/system/ufw.service; enabled; vendor preset: enabled)
   Active: active (exited) since Fri 2026-01-23 14:35:36 UTC; 17min ago
     Docs: man:ufw(8)
   Main PID: 676 (code=exited, status=0/SUCCESS)
     CPU: 2ms

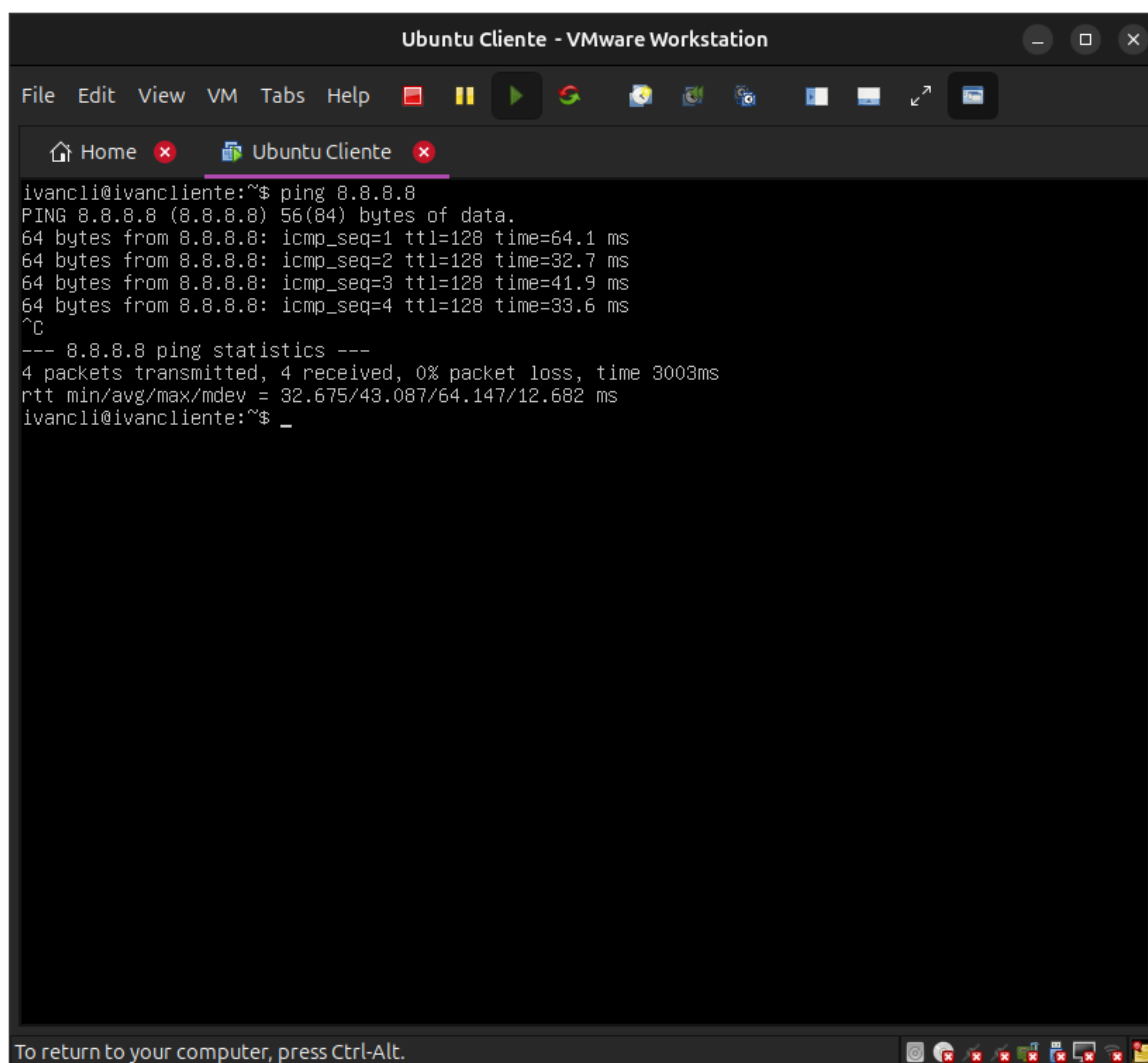
ene 23 14:35:36 ivancli systemd[1]: Starting Uncomplicated firewall...
ene 23 14:35:36 ivancli systemd[1]: Finished Uncomplicated firewall.
ivancli@ivancli:~$
```

Ahora vamos a permitir el tráfico de los protocolos ssh y https

Para eso ejecutaremos el **comando `sudo ufw allow https`** y **`sudo ufw allow ssh`**

Luego de eso lo recomendable es hacer un reseteo del servicio ufw con el **comando `sudo systemctl restart ufw`**

Y por último ejecutaremos el **comando `sudo systemctl status ufw`** para comprobar el estado del servicio y ver que no hay ningún problema



```
ivancli@ivancliente:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=128 time=64.1 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=128 time=32.7 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=128 time=41.9 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=128 time=33.6 ms
^C
--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3003ms
rtt min/avg/max/mdev = 32.675/43.087/64.147/12.682 ms
ivancli@ivancliente:~$ _
```

Ahora comprobaremos que nuestra máquina sigue teniendo internet. Como no tengo interfaz gráfica para abrir google y buscar algo, lo he comprobado con el **comando ping 8.8.8.8** y vemos que no hay ninguna perdida de paquetes por lo que significa que tenemos conexión a internet



4. Protección ataques fuerza bruta con Fail2Ban

Para instalar Fail2Ban tendremos que ejecutar el **comando** `sudo apt install fail2ban`

```
Ubuntu Cliente - VMware Workstation
File Edit View VM Tabs Help
Home x Ubuntu Cliente x
ivancli@ivancliente:~$ sudo systemctl status fail2ban
* fail2ban.service - Fail2Ban Service
   Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; vendor preset: enabled)
   Active: inactive (dead)
   Docs: man:fail2ban(1)
ivancli@ivancliente:~$ sudo systemctl enable fail2ban
Synchronizing state of fail2ban.service with SysV service script with /lib/systemd/systemd-sysv-inst
all.
Executing: /lib/systemd/systemd-sysv-install enable fail2ban
ivancli@ivancliente:~$ sudo systemctl status fail2ban
* fail2ban.service - Fail2Ban Service
   Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; vendor preset: enabled)
   Active: inactive (dead)
   Docs: man:fail2ban(1)
ivancli@ivancliente:~$ sudo systemctl restart fail2ban
ivancli@ivancliente:~$ sudo systemctl status fail2ban
* fail2ban.service - Fail2Ban Service
   Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2026-01-23 14:56:08 UTC; 2s ago
   Docs: man:fail2ban(1)
  Main PID: 39998 (fail2ban-server)
    Tasks: 5 (limit: 4512)
  Memory: 12.1M
     CPU: 187ms
    CGroup: /system.slice/fail2ban.service
            └─39998 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

ene 23 14:56:08 ivancliente systemd[1]: Started Fail2Ban Service.
ene 23 14:56:08 ivancliente fail2ban-server[39998]: Server ready
ivancli@ivancliente:~$ _
```

To return to your computer, press Ctrl-Alt.

Comprobaremos el estado del servicio de fail2ban con el **comando** `sudo systemctl status fail2ban`. Como podemos ver en la primera parte sale que está inactivo por lo que vamos a activarlo con el **comando** `sudo systemctl enable fail2ban`

Es **importante reiniciar** el servicio para que coja la configuración correcta con el **comando sudo systemctl restart fail2ban** y lo volveremos a comprobar con el **comando sudo systemctl status fail2ban** y ya si vemos que el servicio está activo

```
GNU nano 6.2 jail.conf
#
# JAILS
#
#
# SSH servers
#
[sshd]
# To use more aggressive sshd modes set filter parameter "mode" in jail.local:
# normal (default), ddos, extra or aggressive (combines all).
# "mode" can be "filter.d/sshd.conf" or "filter.d/sshd.conf" for usage example and details.
#mode = normal
port = ssh
logpath = %(sshd_log)s
backend = %(sshd_backend)s

[dropbear]
port = ssh
logpath = %(dropbear_log)s
backend = %(dropbear_backend)s

[selinux-ssh]
port = ssh
logpath = %(auditd_log)s

#
^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute  ^C Location  M-U Undo
^X Exit      ^R Read File ^M Replace   ^U Paste     ^J Justify  ^_ Go To Line M-E Redo

To return to your computer, press Ctrl-Alt.
```

Vamos a configurar el servicio de fail2ban para que nos proteja el protocolo ssh. Tendremos que ir a la ruta **/etc/fail2ban** y ejecutaremos el **comando sudo nano jail.conf**

En el archivo añadiremos lo que aparece en la imagen



```
# SSH servers
#

[sshd]

# To use more aggressive sshd modes set filter parameter "mode" in jail.local:
# normal (default), ddos, extra or aggressive (combines all).
# See "tests/files/logs/sshd" or "filter.d/sshd.conf" for usage example and details.
#mode      = normal
port       = ssh
logpath    = %(sshd_log)s
backend    = %(sshd_backend)s

[dropbear]

port       = ssh
logpath    = %(dropbear_log)s
backend    = %(dropbear_backend)s

[selinux-ssh]

port       = ssh
logpath    = %(auditd_log)s

#

ivanccli@ivanccliente:/etc/fail2ban$ sudo fail2ban-client status
sudo: fail2ban: command not found
ivanccli@ivanccliente:/etc/fail2ban$ sudo fail2ban-client status
Status
|- Number of jail:      1
|- Jail list:  sshd
ivanccli@ivanccliente:/etc/fail2ban$ _

To return to your computer, press Ctrl-Alt.
```

Con el **comando sudo fail2ban-client status** comprobaremos que el servicio de sshd está protegido. Como vemos en la imagen tendrá que aparecer **Jail list: sshd**



Ahora realizaremos un ataque de fuerza bruta con otra máquina para comprobar que el servicio de fail2ban está funcionando correctamente. Para eso tendremos que tener instalado hydra con el **comando** **sudo apt install hydra** y nos hará falta el diccionario de rockyou.txt que lo podemos encontrar e instalar en github.com

Cuando tengamos estas dos cosas instaladas ejecutaremos el **comando** **sudo hydra -l root -P /usr/share/wordlists/rockyou.txt -t 7 ssh://(ip de la maquina victima)**



```
ivanccli@ivanccliente:/etc/fail2ban$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:e9:62:29 brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.216.128/24 metric 100 brd 192.168.216.255 scope global dynamic ens33
        valid_lft 1428sec preferred_lft 1428sec
    inet6 fe80::20c:29ff:fee9:6229/64 scope link
        valid_lft forever preferred_lft forever
3: ens37: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000
    link/ether 00:0c:29:e9:62:33 brd ff:ff:ff:ff:ff:ff
    altname enp2s5
ivanccli@ivanccliente:/etc/fail2ban$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed:    35
| -- File list:      /var/log/auth.log
- Actions
  |- Currently banned: 1
  |- Total banned:    1
  -- Banned IP list:  192.168.216.129
ivanccli@ivanccliente:/etc/fail2ban$
```

En la máquina donde tenemos instalado el servicio de fail2ban ejecutaremos el **comando** **sudo fail2ban-client status sshd** y tendremos que ver que en la zona de **Banned IP list** aparezca la IP baneada. También podremos ver el número de intentos fallidos que ha realizado



5. Seguridad en Capas

¿Qué protege el firewall perimetral?

Lo que protege es la red interna, controla las conexiones entrantes y salientes, los servicios como los de web, VPN, correo electrónico, etc

¿Qué protege ufw en el equipo?

Protege los puertos y los servicios del equipo, el tráfico entrante y saliente del equipo y bloquea los ataques de fuerza bruta

¿Por qué es importante combinar ambas medidas?

Porque si una de las dos fallas sigue teniendo la otra capa de seguridad o si alguna de las dos es superada tenemos la otra. Con el firewall perimetral protegemos la red completa y con el ufw le damos una seguridad extra a cada dispositivo

6. Conclusión final

Como conclusión he llegado a que el servicio de Fail2Ban es super importante tenerlo en tu dispositivo ya que bloquea los ataques de fuerza bruta. Tener el ufw activado y configurado en tu dispositivo es importante ya que tienes una capa de seguridad en el dispositivo, puedes bloquear



los tráficos, abrir o cerrar puertos y bloquear el tráfico por distintos puertos según tu uso

Con el servicio de lynis es una buena herramienta para hacer hardening en tu dispositivo y poder mejorar la seguridad del dispositivo